Case 03 · Threat model: the two survivors

A shared threat model for Roll Transparency Log and Removal Sample Audit, STRIDE-style: attacker, goal, method, and what each system does. Scenarios are fictional; figures come from the case's POCs.

What we protect

The integrity of the past; the voter's time to appeal; the neighbours' privacy; the truth of the district number.

Attackers

Attacker	Wants	Has
Insider operator	Delete or change unseen	Servers, code, database
Pressured officer	Meet a deletion target	Terminal, choice of code
Local political actor	Learn who moved, from which community	Everything public
Impersonator	Check another voter, or send a fake SMS	Someone else's elector number
Field checker from the machinery	Confirm deletions without visiting	The field app

Roll Transparency Log

#	Threat	Defence	Status
T1	Operator rewrites an old line	Consistency proofs; witnesses keep old heads (caught in the POC)	Closed
T2	Split view	Head valid only with 3 of 5 witnesses who compare	Closed
T3	Change bypasses the log	No "saved" without receipt; nightly reconciliation	Closed
T4	Neighbours read who left	Public feed by district and week only	Closed, with DPIA
T5	Dictionary of numbers	HMAC key inside an HSM	Closed
T6	Checking another voter	Date of birth required; rate limit	Partial
T7	Draft-day load	Static tiles on a CDN	Closed
T8	Officer records R-DEAD for a living person	Mandatory evidence; the person is told and can appeal	**Partly open: the log does not know truth**
T9	Fake SMS	Identified sender; no data requested; verification on the phone	Partial

Removal Sample Audit

#	Threat	Defence	Status
A1	Steered sample	Public seed, reproducible draw	Closed
A2	List changed after the draw	Freeze and hash before the draw	Closed
A3	Checker confirms without visiting (a quarter → estimate 11%, coverage 1.8%)	Revisits, door photo, location; but nobody establishes an independent pool	**Open: why it fell**
A4	Visited addresses leak	Encrypted to checkers; aggregate results	Closed
A5	"11% wrong" becomes a slogan	Always with margin, method and seed	Partial

What the threat model changed

Log: aggregate publication (T4), witness cosigning as a validity condition (T2), mandatory evidence (T8).
Audit: freezing the list (A2); A3 stayed open and felled it at architecture.